ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Endress+Hauser Proline Promag P 300 / P 500 Electromagnetic Flowmeter (HART / Modbus / EtherNet/IP / PROFINET) · Component type: **Embedded Device (EDR) - field instrument / flowmeter** · Target SL = SL 3

Where to work	Local **onsite display** (4-line, touch/keys) menus Operation/Setup/Diagnostics/Expert; the integrated **Web server** via the **CDI-RJ45 service interface** (or WLAN); **FieldCare / DeviceCare** (FDT/DTM) via CDI-RJ45, HART or fieldbus; the **WP DIP switch** on the main electronics module. Firmware/config via FieldCare/DeviceCare/web.
Ports / paths	Web server = **HTTP TCP 80** on the service interface (password sent encrypted; default AP IP 192.168.1.212). WLAN (option) = **WPA2**. Process comms by variant: **HART** = 4-20 mA + HART FSK (Bell 202); **Modbus** = RS485 serial (RTU/ASCII); **EtherNet/IP** = TCP 44818 (explicit), UDP 2222 (I/O), UDP 44818 (ListIdentity); **PROFINET** = PN-RT L2 (0x8892), DCP (L2), TCP 34964 (PN-CM), SNMP UDP 161, LLDP (Ethernet-APL option).
300 vs 500	Both models run the **same Proline firmware and identical operating menu**, web server, access-code/user-role model, WP DIP switch, WLAN, and comm variants - so the security testing is the same. **P 300** = compact (transmitter integral to the sensor, one housing). **P 500** = **digital remote transmitter** in a separate housing, connected to the sensor by a **connecting cable up to 300 m** - the only material difference is added physical surface (two housings + cable), reflected in the physical/tamper rows.
Notes	EDR - field instrument (electromagnetic flowmeter), Proline Promag **P 300 (compact) / P 500 (remote transmitter)**. Confirm firmware, the comm variant, and whether the **WLAN** option is fitted. Delivered with **no access code** (= full Maintenance access) and HW write protection **off** - both must be set for SL-3. The device has no secure-boot / signed-firmware root of trust published - those rows route to compensating provenance controls.
How to read	Each row = one SL-3 requirement with native step-by-step (exact display/web path or WP switch) + command-level external-tool steps; **By variant** = per-protocol specifics, **By model** = P 300 vs P 500 specifics. Default read-only. Scans authorized; fuzz ISOLATED lab only.

Project / config capture & evidence handling - capture the device backup + config export

Do this BEFORE working the checklist - screenshots and walking the config screens are not enough on their own. Capture the device's own backup / project export so nothing is missed:
1. Pull the native backup / project + full config export first (read-only, before anything): the **FieldCare / DeviceCare** DTM parameter backup (Save/Restore dataset) - or the device **Save/Load** via the web server / local display - the HART/Modbus-RS485/EtherNet-IP/PROFINET + Web-server access-code / WLAN settings, firmware rev, and the diagnostic event logbook.
2. Export the security-relevant settings: user accounts / roles / password policy, comms / port / protocol enable-disable, and any certificate / key / CIP-Security settings - as files and screenshots.
3. Collect firmware & logs: firmware / boot revision, and the event / audit / diagnostic logs and fault / alarm buffers (exports) where the device provides them.
4. Capture the device identity: nameplate (catalog + serial), firmware / hardware rev, installed modules / option cards, and slot / network address - **photograph** the device, faceplate / HIM and panel labels.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<vendor>_<model>_<fwRev>_<YYYYMMDD-HHMM>_<initials>` with the native project / backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup may hold credentials / keys - **never** email it in cleartext and follow the project retention / classification policy. Do not save device passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user identification & auth	The device uses **user roles** (Operator = read; Maintenance = read/write) gated by a **user-specific access code**. It ships with **no access code** (everyone = Maintenance). Set one: **Setup › Advanced setup › Administration › Define access code**. The same access code protects the **Web server** login and FieldCare/DeviceCare write access. **Test:** from the display/web as Operator (or with no code), attempt to edit a parameter -> must prompt for the access code / be read-only. **Ext. tools:** Web browser to `http://<svc_ip>` (login prompt appears); DeviceCare via CDI-RJ45 (role shown); `nmap -p 80 <svc_ip>` (web reachable = in scope).	Access code set (non-default); Operator/Maintenance roles enforced on display, web, and FieldCare.	
SR/CR 1.2	Software process / device identification	Confirm the device is uniquely identified (tag/TAG, serial, and the process-network identity). **By variant:** **HART** - unique HART polling address/long tag; **Modbus** - unique RS485 slave address; **EtherNet/IP** - unique IP/host name; **PROFINET** - unique station name + IP (assigned by DCP). **Ext. tools:** EtherNet/IP: `nmap -sU -p 44818 --script enip-info <ip>`; PROFINET: Wireshark `pn_dcp` (station name); HART/Modbus: DeviceCare device info (address/serial).	Unique device identity per the variant; addresses not reused.	
SR/CR 1.3	Account management	The device has fixed roles (Operator/Maintenance), not named accounts - manage the shared access code (and WLAN passphrase) as controlled secrets: least distribution, rotation, no defaults. Named-user accountability is enforced at the operating-tool/EWS layer. **Ext. tools:** Access-code/passphrase custody record; FieldCare server user review (who may go online).	Access code + passphrase controlled/rotated; roles least-privilege; tool-layer accountability.	Compensating.
SR/CR 1.4	Identifier management	Confirm a unique device identity (tag, serial, and variant address/name) - no reuse across meters; operating-tool user IDs unique. **Ext. tools:** Asset register vs device info (DeviceCare); network inventory for IP/station-name variants.	Unique device and user identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Set a strong access code (change from the delivered no-code state) and, if WLAN is fitted, a strong **WLAN passphrase** (WPA2). Record both in the credential vault. Note: the access code is numeric - compensate the limited strength with physical + network controls. **Ext. tools:** Display/web (confirm access code set); WLAN settings submenu (passphrase changed from default = serial number).	Access code + WLAN passphrase set/strong; delivered defaults changed.	
SR 1.6	Wireless access management	If the **WLAN option is fitted:** in the **WLAN settings** submenu confirm **WLAN security mode = WPA2**, a non-default **WLAN passphrase** (default = device serial number), a controlled **SSID**, and set **WLAN mode** deliberately (Access point vs infrastructure). Disable WLAN if not required. **Test:** scan for the device SSID; confirm WPA2 (not open/WEP) and that it is off if unused. **Ext. tools:** WLAN scanner / `nmcli dev wifi list` (SSID + WPA2); if not fitted: confirm no WLAN module present -> mark N/A. **If no WLAN fitted:** N/A - record that the order code has no WLAN module.	WLAN WPA2 + strong passphrase, or WLAN absent/disabled (N/A recorded).	
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	**N/A / limited at the device.** The Promag 300 web server uses an encrypted password exchange but is not a full asset-owner-PKI TLS endpoint, and the fieldbus variants have no device PKI. Record N/A with justification; provide confidentiality/integrity via segmentation and TLS at the SCADA/EWS layer. **Ext. tools:** Confirm no configurable device certificate; if the web offers HTTPS on the firmware rev, `openssl s_client -connect <svc_ip>:443`.	N/A/limited device PKI; compensating TLS/segmentation upstream.	N/A/Partial.
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm the access-code entry on the display and the Web server login mask the digits (no cleartext echo). **Ext. tools:** Visual verification (display + browser login field).	Authenticators obscured during entry.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.11	Unsuccessful login attempts	The device does not natively lock out after failed access-code entries - record as a residual; mitigate by physical access control, network segmentation, and monitoring the web/service interface. Any operating-tool/EWS lockout applies at that layer. **Ext. tools:** Confirm no native lockout (doc/observe); SIEM/IDS on the service-interface segment for repeated web-auth failures.	No native lockout - residual recorded + compensating controls.	Partial/Compensating.
SR/CR 1.12	System use notification	No native logon banner on the device; enforce the approved use notice at the EWS (GPO) and any SCADA HMI that fronts the meter (compensating). **Ext. tools:** EWS `gpresult /h gp.html`; HMI banner screenshot.	Use notice at EWS/HMI (compensating at device).	Compensating.
SR 1.13	Access via untrusted networks	Confirm the meter is reachable only from the trusted process/segmented zone; the service interface/WLAN is not exposed to untrusted networks; remote engineering via VPN/jump host. **Test:** from an untrusted VLAN/off the plant Wi-Fi, attempt to reach the web server / fieldbus - must fail. **Ext. tools:** `nmap -Pn -p 80,44818,34964,502 <ip>` from the untrusted side (expect filtered); firewall/ACL review; confirm WLAN not bridged to untrusted nets.	Untrusted-network access denied; remote via VPN; WLAN not bridged.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	Confirm least privilege via the two mechanisms: (1) **software** - Operator role + access code make config read-only without the code; (2) **hardware** - the **WP DIP switch** on the main electronics module (ON = write-protected) overrides everything including the access code. Check the **Locking status** parameter (Setup / Diagnostics) to see whether Hardware locked / Access code locked is active. **Test:** with the WP switch ON, attempt any write from display/web/FieldCare -> refused regardless of access code. **Ext. tools:** Display/web (Locking status = Hardware/SW locked); DeviceCare write attempt (isolated) -> refused.	Access code + WP DIP switch enforce least privilege; Locking status confirms; negative test denies.	
SR/CR 2.2	Wireless use control	If WLAN is fitted, confirm WLAN write access is governed by the same access code + WP switch and WPA2 - a WLAN client cannot bypass write protection. Disable WLAN if not needed. **If no WLAN:** N/A (no wireless interface). **Ext. tools:** WLAN client to the web server -> still requires access code; confirm WP switch also blocks WLAN writes; or mark N/A if not fitted.	WLAN write access controlled the same as wired, or N/A (no WLAN).	
SR 2.3	Use control for portable/mobile devices	Control the FieldCare/DeviceCare laptop and any USB/CDI adapter; removable-media policy on the EWS; only authorized DTMs/firmware loaded; secure the CDI-RJ45 port physically. **Ext. tools:** EWS removable-media GPO review; physical inspection of the CDI-RJ45 service port.	Portable/engineering media and service port controlled.	
SR/EDR 2.4	Mobile code	No general-purpose mobile code on the meter; the web server uses vendor JavaScript only (no user script path); confirm only device firmware + configured parameters run. **Ext. tools:** Browse the web server read-only (vendor content only); confirm no upload of executable content beyond signed firmware/config.	Only trusted firmware/config runs; no untrusted mobile code.	EDR-specific.
SR/CR 2.5	Session lock	Confirm the web server / FieldCare session and the display return to a protected state on inactivity (re-entry of the access code required to edit again). **Ext. tools:** Leave web/display idle then retry an edit -> access-code prompt; check web session timeout.	Sessions revert to protected state on inactivity.	
SR/CR 2.6	Remote session termination	Confirm web-server / FieldCare sessions can be closed and idle sessions end; only authorized hosts can reconnect (segmentation + access code). **Ext. tools:** Web logout / session review; Wireshark (session teardown).	Remote sessions terminable on demand and on inactivity.	
SR/CR 2.7	Concurrent session control	Confirm concurrent access is bounded (the web server supports a limited number of sessions) so simultaneous conflicting configuration is prevented. **Ext. tools:** Open a second web session -> bounded/blocked; observe behavior.	Concurrent privileged sessions limited.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.8	Auditable events	The meter keeps an **Event logbook** (Diagnostics › Event logbook) of diagnostics/config events but has no per-named-user audit. Capture configuration changes and attribution in **FieldCare** (change records) / the SCADA historian, and forward to the SIEM. **Ext. tools:** Display/web (Diagnostics › Event logbook export); FieldCare change log; SIEM ingest of the collector.	Config events captured (event logbook + FieldCare); attribution at the tool layer.	Compensating.
SR/CR 2.9	Audit storage capacity	The device event logbook is a fixed-depth ring (e.g. 20 entries) - rely on FieldCare/SCADA/SIEM for retention; confirm sizing and alerting. **Ext. tools:** Confirm logbook depth; SIEM/historian retention config.	Events offloaded and retained; alert before capacity.	
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM/historian alerts on collection failure so meter events are not silently lost. **Ext. tools:** SIEM source-silent alert; historian collector health.	Audit-failure alerting defined.	
SR/CR 2.11	Timestamps	The meter has an internal clock but no independent NTP on the fieldbus; confirm time is set/synced (PROFINET can sync; otherwise event-logbook time is set via the tool) and that upstream SCADA/SIEM timestamps correlate. **Ext. tools:** Display (date/time config); for PROFINET, Wireshark time sync; correlate with SCADA clock.	Reliable, synchronized timestamps for meter events.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
EDR 2.13	Physical diagnostic & test interfaces	Control physical interfaces: lock the transmitter housing; set the **WP DIP switch ON**; secure the **CDI-RJ45** service port and (if fitted) disable WLAN; **disable the Web server if unused** (Expert › Communication › Web server › Web server functionality = Off, which locks port 80). **By model: P 500** - secure **both** the remote transmitter housing (where the WP switch, service port and display live) **and** the sensor connection housing, and protect the **connecting cable** route (up to 300 m) against tap/tamper; the WP DIP switch is on the transmitter main electronics module. **P 300** - single integral housing. **Ext. tools:** Physical inspection (both housings + cable route on P 500; WP switch); display/web (Web server functionality = Off); `nmap -p 80 <svc_ip>` (closed when disabled).	Housing(s) locked; WP on; service port/WLAN/web disabled unless required; P 500 cable route protected.	EDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	The web-server login/password is transferred encrypted; process-fieldbus traffic is **not** natively authenticated/encrypted, so contain it by segmentation. **By variant: HART** - use HART write-protection/lock; **Modbus RS485** - no auth, segment the serial run; **EtherNet/IP** - unauthenticated CIP, keep in-zone; **PROFINET** - enable **DCP write protection (DCP read-only)** so station name/IP cannot be reassigned. **Ext. tools:** Wireshark on the process link (confirm cleartext stays in-zone); EtherNet/IP `nmap --script enip-info`; PROFINET confirm DCP-Set blocked.	Web login encrypted; fieldbus contained/segmented; PROFINET DCP write-protected.	
SR/EDR 3.2	Protection from malicious code (component)	Confirm only E+H firmware runs and there is no code-execution path. The Promag 300 does not publicly document signed-firmware verification - control firmware provenance from the E+H portal and the update path tightly (2.3/3.10). **Ext. tools:** DeviceCare (firmware version); verify the firmware file provenance vs the E+H software portal.	Only vendor firmware runs; provenance verified; no code path.	EDR-specific/Partial.
SR/CR 3.3	Security functionality verification	After any change re-verify: access code set, WP switch ON, Web server state, WLAN state, and (PROFINET) DCP write protection, against the hardening baseline; compare the FieldCare/DeviceCare parameter export. **Ext. tools:** DeviceCare (Locking status + settings vs baseline export); `nmap -p 80,44818,34964 <ip>` (services as expected).	Security-relevant settings match the baseline after change.	
SR/CR 3.4	Software & information integrity	Archive the FieldCare/DeviceCare parameter set, enable change detection, and keep the WP switch ON so unauthorized parameter/firmware change is prevented/detected. Compare online-vs-saved. **Ext. tools:** DeviceCare (save/compare parameter set); Locking status = Hardware locked.	Config integrity protected; unauthorized change prevented/detected.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.5	Input validation	Confirm the meter tolerates malformed protocol frames without malfunction. **ISOLATED only:** fuzz the relevant interface (EtherNet/IP or PROFINET or Modbus) on a bench meter and watch measurement/diagnostics. **Ext. tools:** ENIP/Modbus/PROFINET fuzzer (`boofuzz`) on a bench unit; Wireshark; watch the event logbook.	No malfunction on malformed input.	Do NOT fuzz an in-service meter.
SR/CR 3.6	Deterministic output	Verify the configured **failsafe/fault behavior** of the outputs (current output failure mode, and fieldbus comm-failure behavior) so the meter drives a defined value on fault/comm loss. **By variant:** HART/analog - current-output failure mode (e.g. 3.6 mA / 22 mA); EtherNet/IP-PROFINET-Modbus - fieldbus comm-failure substitute value/status. **Ext. tools:** DeviceCare (Output / failure mode config); simulate a fault (Diagnostics › Simulation) -> confirm the defined output.	Outputs assume a defined failsafe value on fault or comm loss.	
SR/CR 3.7	Error handling	Confirm graceful diagnostics handling (NAMUR NE107 categories: Failure/Function check/Out of spec/Maintenance) without info leakage; review the diagnostics list. **Ext. tools:** Display/web (Diagnostics › active diagnostics + event logbook).	Graceful NE107 diagnostics; no unsafe state or info leak.	
SR/CR 3.8	Session integrity	The web-server session uses an encrypted password exchange; process-fieldbus has no secured session - rely on containment. Record accordingly. **Ext. tools:** Wireshark (web session; confirm fieldbus contained in-zone).	Web session integrity via encryption; fieldbus contained.	Partial.
SR/CR 3.9	Protection of audit information	Protect the FieldCare change records / historian and restrict who can clear the device event logbook (Maintenance role + WP). **Ext. tools:** FieldCare/historian access review; confirm logbook clear requires Maintenance.	Audit records protected from unauthorized read/modify/delete.	
EDR 3.10	Support for updates	Update firmware via FieldCare/DeviceCare/web with firmware obtained from the E+H portal; verify the version and provenance; plan the update in a maintenance window with the loop out-of-service and a rollback to the prior version. (No on-device signature guarantee published - provenance discipline is the control.) **Ext. tools:** DeviceCare (firmware update flow); E+H portal provenance/version check.	Controlled updates from a verified source, with rollback.	EDR-specific/Partial.
EDR 3.11	Physical tamper resistance/detection	Keep the transmitter housing locked/sealed; the WP DIP switch inside adds tamper resistance; the event logbook records config changes as tamper evidence; seal the housing where required. **By model:** **P 500** - seal both housings and inspect the connecting cable/glands for tamper (the remote cable is an added tamper surface); **P 300** - single sealed housing. **Ext. tools:** Physical inspection (housing lock/seal + P 500 cable/glands, WP switch); event-logbook review for unexpected changes.	Housing(s) locked/sealed; WP set; changes logged; P 500 cable inspected.	EDR-specific.
EDR 3.12	Provisioning product-supplier roots of trust	**Partial/N-A at device.** The Promag 300 does not publicly document a signed-boot supplier root of trust. Record the gap; compensate via firmware-provenance discipline (3.10), physical control, and segmentation. **Ext. tools:** Confirm no documented secure-boot/signed-firmware root; provenance process review.	No documented supplier RoT; compensating controls recorded.	Partial/N-A.
EDR 3.13	Provisioning asset-owner roots of trust	**Partial/N-A at device.** No asset-owner certificate provisioning on the meter. Record the gap; asset-owner trust is enforced at the SCADA/EWS layer and by segmentation. **Ext. tools:** Confirm no device certificate provisioning capability.	No asset-owner RoT; compensating controls recorded.	Partial/N-A.
EDR 3.14	Integrity of the boot process	**Partial/N-A at device.** No published verified/secure boot. Record the gap; mitigate via controlled firmware provenance (3.10), physical control (WP + housing), and monitoring. **Ext. tools:** Confirm no secure-boot capability; DeviceCare firmware version.	No documented verified boot; compensating controls recorded.	Partial/N-A.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.2	Information persistence	On decommission/repurpose, reset the device (Setup › Advanced setup › Administration › **reset measuring device** / restart) and clear the access code and WLAN passphrase so configuration/credentials are not recoverable. **Ext. tools:** Display/DeviceCare (reset measuring device; clear access code + WLAN passphrase).	Settings and credentials purged on decommission.	
SR/CR 4.3	Use of cryptography	The web-server login/password is transferred encrypted; WLAN uses WPA2. No other native crypto - disable the web server/WLAN if unused and rely on TLS at the SCADA/EWS layer and segmentation. **Ext. tools:** Confirm web password encrypted (On mode); WLAN = WPA2; disable unused services.	Web/WLAN crypto used; unused services disabled; compensating upstream TLS.	Partial.

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	Confirm the meter sits in a controlled process cell/zone behind a firewall / managed switch; only the required protocol crosses the boundary; the service interface/WLAN are not bridged to IT. **By variant:** open only the variant port(s) - HART loop stays analog; Modbus RS485 physically isolated; EtherNet/IP 44818/2222; PROFINET DCP/34964/RT within the PN cell. **Ext. tools:** `nmap -p 80,502,44818,34964 <ip>` per zone; firewall/ACL review; confirm service-interface VLAN isolation.	Meter in a segmented zone; only required flows cross the boundary.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Single-purpose field instrument with no general-purpose person-to-person communications. **Ext. tools:** Confirm no such services on the device.	N/A - justification recorded (single-purpose embedded device).	N/A
SR 5.4	Application partitioning	**N/A.** Single-purpose meter; no separable applications to partition. **Ext. tools:** Confirm single-function device.	N/A - justification recorded.	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Confirm the device **Event logbook** and diagnostics are readable/exportable (display/web/FieldCare) and that meter status is monitored via SCADA + a passive OT IDS on the process segment. **Ext. tools:** Display/web (Event logbook export); SCADA alarm on device status; passive OT IDS (Nozomi/Dragos) on the cell SPAN.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	Confirm the meter tolerates network load without losing measurement/output; the fieldbus stack bounds connections and the cell firewall rate-limits. **By variant:** EtherNet/IP-PROFINET are the DoS-relevant variants (Ethernet); HART/Modbus-RS485 are point-to-point/serial. **Ext. tools:** ISOLATED bench: `hping3 --flood` / ENIP storm on an Ethernet variant; watch measurement + event logbook.	Measurement/output continues under load; resources bounded.	
SR/CR 7.2	Resource management	Confirm the comm stack bounds resource use (connection limits) so a single service cannot starve the measurement function (measurement has priority). **Ext. tools:** Fieldbus connection limits; bench load test with measurement monitoring.	Resources bounded; measurement unaffected by service load.	
SR/CR 7.3	Control system backup	Confirm the FieldCare/DeviceCare parameter set (and the **HistoROM** device memory) provides backup/restore, and a restore is tested (e.g. to a replacement electronics module) for a known-good rebuild. **Ext. tools:** DeviceCare (Data management - save/restore); HistoROM backup/restore test.	Backups current (FieldCare + HistoROM) and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency power	**N/A.** Backup power is a facility/loop-power concern, not the device; confirm the device retains its configuration and security state across a power cycle. **Ext. tools:** Power-cycle test -> config + access code + WP retained.	N/A - device retains state across power transfer.	N/A
SR/CR 7.6	Network & security configuration settings	Harden per the E+H IT-security guidance: set the access code, WP switch ON, **disable the Web server if unused** (Web server functionality = Off -> port 80 locked), disable/secure WLAN, and (PROFINET) enable DCP write protection; disable any unused protocol/service. **Ext. tools:** Display/web (Web server functionality=Off; WLAN off; DCP read-only); `nmap -p 80,44818,34964,502 <ip>` (only required reachable).	Least functionality; unused services disabled per baseline.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Confirm the meter (order code, firmware version, comm variant/module, WLAN option) is inventoried so vulnerabilities track against E+H security advisories / the CSA feed. **Ext. tools:** DeviceCare device info (order code/firmware); E+H Security Advisories; passive OT IDS inventory.	Accurate device/firmware inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Onsite display	Native config & lock review (all FRs)	Operation/Setup/Diagnostics/Expert menus. Setup › Advanced setup › Administration › Define access code; check Locking status; Diagnostics › Event logbook; Expert › Communication › Web server.	Physical; authorized.
Web server (browser via CDI-RJ45 / WLAN)	Remote config & hardening (1.1, 2.13, 7.6)	Browse http://<svc_ip> (default AP 192.168.1.212); log in with the access code; Expert › Communication › Web server › Web server functionality = Off to disable (locks port 80).	Read-only unless authorized to change.
FieldCare / DeviceCare (FDT/DTM)	Parameter review, backup, firmware (2.8, 3.3, 3.4, 7.3, 3.10)	Connect via CDI-RJ45 / HART / fieldbus; read Locking status and settings; Data management save/compare; controlled firmware update.	Read/authorized project copy.
WP DIP switch (main electronics module)	Hardware write protection (2.1, 2.13, 3.4)	Set WP switch ON to hardware-lock all writes (overrides the access code); confirm via Locking status = Hardware locked.	Physical; de-energize per procedure.
nmap	Service/port exposure & segmentation (1.1, 1.13, 3.1, 5.x, 7.6)	`nmap -p 80,44818,34964,502 <ip>` - confirm only the required variant port + service web are reachable; `nmap -sU -p 44818 --script enip-info` (EtherNet/IP identity); scan per zone.	Read-only; authorized.

Tool / method	Verifies	How to use — steps / example	Constraints
Wireshark / tcpdump	Comms integrity & identity (1.2, 3.1, 3.8)	Filter `enip || pn_dcp || modbus`; confirm web login encrypted, fieldbus contained in-zone, PROFINET DCP-Set blocked.	Passive; SPAN/tap only.
WLAN scanner	Wireless hardening (1.6, 2.2)	`nmcli dev wifi list` / a WiFi analyzer - confirm the device SSID uses WPA2 (not open/WEP), non-default passphrase, and is off if unused; or confirm no WLAN module.	Passive.
ENIP/Modbus/PROFINET fuzzer / hping3	Input validation & DoS resilience (3.5, 7.1)	`boofuzz` harness for the fitted Ethernet variant; `hping3 --flood` storm on a bench meter; watch measurement + event logbook.	ISOLATED bench; never in-service.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.